

Vulnerability Assessment Report of Findings

MetaBananaCat S.r.l.

NemiSec

Emy Mangogna – emanuela.mangogna@gmail.com

20/9/2025

Table of contents

Engagement Contacts.....	p2
Executive Summary.....	p3
○ Approach.....	p3
○ Scope.....	p3
○ Assessment overview.....	p4
○ Recommandations.....	p6

Engagement Contacts

MetaBananaCat Contacts		
Primary Contact	Title	Primary Contact Email
Mr FlyffyChonk	Chief Executive Officer	chonk@miao.com
Secondary Contact	Title	Secondary Contact Email
Mr Wiskerpuff	Chief Technical Officer	purrrpurrr@miao.com

Assessor Contacts		
Assessor Name	Title	Email
Emy Mangogna	Security Consultant	emanuela.mangogna@gmail.com

Executive Summary

MetaBanana S.r.l. ha incaricato **NemiSec** di eseguire un assessment vulnerability interna al fine di identificare punti deboli di sicurezza, valutare il loro impatto sull'azienda, documentare i risultati in modo chiaro e ripetibile e fornire raccomandazioni di mitigazione.

Approach

La valutazione è stata condotta con strumenti di scansione automatizzata (Nessus) e validazione manuale dei risultati. Le vulnerabilità sono state classificate in base alla loro severità e potenziale impatto sul business di **MetaBanana**. Tutte le vulnerabilità rilevate sono state documentate e corredate di raccomandazioni operative per la mitigazione.

Scope

L'attività di Vulnerability Assessment ha riguardato l'infrastruttura interna di **MetaBanana**, con particolare attenzione ai servizi di rete esposti su sistemi aziendali critici. L'obiettivo è stato identificare vulnerabilità note che potrebbero essere sfruttate da un attaccante interno o esterno per compromettere la sicurezza delle informazioni aziendali. Sono stati inclusi nell'analisi servizi di accesso remoto, servizi applicativi e componenti critici per la continuità operativa.

Obiettivo: identificare e classificare le vulnerabilità presenti, valutare l'impatto aziendale e fornire raccomandazioni prioritarie per la mitigazione e il ripristino sicuro del sistema.

Asset In-Scope:

Host/IP Address	Description
192.168.50.	Server interno MetaBanana

Limitazioni e vincoli: esclusione di attività intrusive o distruttive su sistemi di produzione; nessuna modifica persistente apportata agli host target;

Assessment Overview

Durante il test di sicurezza sono state identificate diverse vulnerabilità critiche nel sistema. Alcune comunicazioni utilizzano protocolli di crittografia obsoleti, che potrebbero permettere a un attaccante di intercettare o modificare i dati trasmessi. Alcuni certificati e chiavi crittografiche risultano deboli, aumentando il rischio che un malintenzionato possa ottenere accesso non autorizzato ai sistemi.

Inoltre, è stata rilevata la presenza di servizi con accesso non protetto, come shell di amministrazione e server VNC con password debole, che potrebbero consentire l'ingresso diretto e il controllo del sistema senza autenticazione. Parte dei sistemi utilizza versioni obsolete del sistema operativo e dei software, che non ricevono più aggiornamenti di sicurezza, aumentando la probabilità di sfruttamento da parte di un attaccante.

In sintesi, queste vulnerabilità rappresentano un rischio significativo per la sicurezza dei dati e dei sistemi aziendali, e richiedono interventi immediati per aggiornare software, disabilitare protocolli insicuri e rafforzare le credenziali di accesso.

SEVERITY	CVSS V 3.0	NAME	DESCRIPTION
CRITICAL	9.8	Bind Shell Backdoor Detection	Indica la possibile presenza di una backdoor che consente accesso remoto non autorizzato.
CRITICAL	9.8	SSL v2/v3 Protocol Detection	Usa protocolli di cifratura vecchi e insicuri che espongono a intercettazioni.
CRITICAL	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	Sistema operativo obsoleto e non più supportato, senza patch di sicurezza.
CRITICAL	10.0	Debian OpenSSH/OpenSSL RNG Weakness	Debolezza critica nella generazione dei numeri casuali: le chiavi crittografiche sono prevedibili.
CRITICAL	10.0	Debian OpenSSH/OpenSSL RNG Weakness (SSL check)	Variante della stessa debolezza che riguarda direttamente le connessioni SSL/TLS.
CRITICAL	10.0	VNC Server 'password' Password	Il server VNC utilizza la password predefinita "password", facilmente sfruttabile.
HIGH	9.8	Apache Tomcat Ghostcat	Permette accesso non autorizzato ai file e al codice del server Tomcat.
MEDIUM	8.6	ISC BIND DoS	Permette a un attaccante di rallentare o bloccare il servizio DNS.
MEDIUM	7.5	NFS Shares World Readable	Le cartelle condivise via NFS sono leggibili da chiunque, esponendo dati sensibili.
MEDIUN	7.5	SSL SWEET32	Usa algoritmi di cifratura deboli (64-bit) che permettono decrittazione del traffico.

Le principali criticità rilevate includono:

CRITICA - Bind Shell / Backdoor: shell remota attiva; rischio: accesso completo non autorizzato.

CRITICA - SSLv2/SSLv3: protocolli deprecati; rischio: MITM/downgrade.

CRITICA - Ubuntu 8.04 EoL: OS fuori supporto; rischio: nessuna patch disponibile.

CRITICA - Debian OpenSSL/SSH RNG Weakness: RNG debole; rischio: chiavi prevedibili e compromissione TLS/SSH.

CRITICA - Debian RNG (SSL check): impatto diretto su sessioni SSL/TLS; rischio: decrittazione.

CRITICA - VNC con password debole: credenziali di default/semplificati; rischio: accesso remoto completo.

ALTA - Apache Tomcat (Ghostcat): AJP vulnerabile; rischio: lettura file ed eventuale RCE.

MEDIA - ISC BIND DoS/Downgrade: BIND suscettibile a attacchi di disponibilità; rischio: interruzione DNS.

MEDIA - NFS World Readable: condivisioni leggibili da chiunque; rischio: leakage dati.

MEDIA - SSL SWEET32 (3DES): cifrari 64-bit supportati; rischio: attacchi di collisione e parziale decrittazione.

Recommendations

Bind Shell / Backdoor: isolare e rimuovere il sistema compromesso.

SSLv2/SSLv3 attivo: disabilitare protocolli obsoleti e usare TLS moderno.

Ubuntu 8.04 EoL: aggiornare a versione supportata.

Debian OpenSSL/SSH RNG Weakness: aggiornare software e rigenerare chiavi.

Debian RNG (SSL check): aggiornare software e rigenerare chiavi SSL/TLS.

VNC con password debole: cambiare password con una sicura.

Apache Tomcat (Ghostcat): aggiornare Tomcat e limitare accessi.

ISC BIND DoS/Downgrade: aggiornare BIND e applicare controlli DoS.

NFS World Readable: limitare accessi e permessi sulle condivisioni.

SSL SWEET32 (3DES): disabilitare cifrari deboli, usare solo cifrari sicuri.